

Botium Toys - Internal IT Audit & Risk Assessment (Cybersecurity Project)

1. Project Title

Internal IT Audit & Risk Assessment for Botium Toys

2. Objective

To conduct an internal cybersecurity audit of Botium Toys using the NIST Cybersecurity Framework (CSF), in order to identify existing security controls, evaluate compliance with standards such as PCI DSS and GDPR, assess risks, and recommend improvements to strengthen the organization's overall security posture.

3. Tools/Frameworks Used

NIST Cybersecurity Framework (CSF)
Payment Card Industry Data Security Standard (PCI DSS)
General Data Protection Regulation (GDPR)
System and Organization Controls (SOC type1 & SOC type2)

4. Scenario Summary (from the assignment)

Botium Toys is a small U.S.-based company that designs and sells toys. Operating from a single physical location that includes their office, storefront, and warehouse, the company has recently expanded its online operations to serve both domestic and international customers. With the growth of their online market, the IT department is facing increased pressure to maintain a secure and compliant infrastructure. To address these concerns, the IT manager initiated an internal audit using the NIST Cybersecurity Framework. The goal was to identify risks, assess critical assets, and evaluate the company's adherence to compliance regulations, including those related to online payments and E.U. customer data protection.

5. Steps Taken

Reviewed **Scope, Goals, and Risk Assessment Report**.

Analyzed **control categories** (Administrative / Managerial, Technical, and Physical) and classification / **types of controls** (Preventive, Corrective, Detective, Deterrent) used by the organization.

Completed the **Controls and Compliance Checklists** such as PCI DSS, GDPR, SOCs (type1 and type2)

6. Key Findings

Key controls such as **least privilege, disaster recovery plans, separation of duties, and encryption** were not implemented. The organization lacked adherence to **PCI DSS best practices** and only partially met **GDPR** requirements.

7. Recommendations

To enhance compliance and reduce the risk of regulatory penalties or reputational

damage, Botium Toys should implement essential security controls including least privilege access, separation of duties, strong password policies, and a centralized password management system.

8. Outcome or Impact

Aligning with recommended controls will significantly reduce the company's attack surface, enhance data protection, and improve compliance posture, thereby lowering the risk of fines and reputational harm.